

Portfolio Desk Information Security Policy

Field	Value
Document owner	Information Security Officer or designated security owner
Business owner	Portfolio Desk executive sponsor
Version	1.0
Effective date	Upon management approval
Review frequency	At least annually and after material security events or architectural changes
Classification	Internal
Approval status	Draft for management approval

1. Purpose

This policy establishes the administrative, technical, and operational requirements used to protect Portfolio Desk information, systems, customers, and users. Its objectives are to preserve:

- **Confidentiality:** information is available only to authorized identities and organizations.
- **Integrity:** records, financial activity, documents, and configuration cannot be altered without authorization and traceability.
- **Availability:** the service and recoverable customer data remain available according to approved operational commitments.

This policy is a governance requirement. Implementation evidence must be verified through configuration reviews, tests, logs, access reviews, vulnerability assessments, and recovery exercises.

2. Scope

This policy applies to:

- The Portfolio Desk backend, customer frontend, administration frontend, landing site, databases, object storage, uploaded documents, APIs, background jobs, and deployment pipelines.
- Development, test, staging, disaster recovery, and production environments.
- Employees, contractors, administrators, support personnel, developers, service accounts, and third parties with access to Portfolio Desk information or systems.
- Customer and organization data, including commercial and residential property information, leases, financial records, maintenance records, contacts, identity data, uploaded documents, and integration credentials.
- External services used by Portfolio Desk, including email, Stripe, Google OAuth, Microsoft or other OIDC providers, AI providers, QuickBooks Online, Plaid, Sentry, AWS, and other approved infrastructure providers.

3. Roles and Responsibilities

3.1 Executive sponsor

The executive sponsor shall:

- Approve this policy and material risk exceptions.
- Ensure sufficient resources are available to operate required security controls.
- Assign accountable owners for security, privacy, operations, and incident response.

3.2 Security owner

The security owner shall:

- Maintain this policy and the security risk register.
- Coordinate risk assessments, vulnerability management, incident response, access reviews, and security training.

- Review security-relevant architecture and material third-party integrations.
- Report significant risks and incidents to management.

3.3 System and data owners

System and data owners shall:

- Define authorized use, retention, recovery, and access requirements for systems and information under their control.
- Review privileged and business access at least quarterly.
- Approve material changes affecting security or customer data.

3.4 Engineering and operations

Engineering and operations personnel shall:

- Follow secure development, change management, secret management, logging, backup, and incident response requirements.
- Apply least privilege and tenant isolation controls in every data access path.
- Remediate vulnerabilities according to Section 12.
- Preserve security evidence needed for investigations and audits.

3.5 Users

Users shall:

- Protect credentials and authentication factors.
- Use Portfolio Desk only for authorized business purposes.
- Report suspected compromise, misdirected data, unauthorized access, and security weaknesses promptly.

4. Information Classification and Handling

Portfolio Desk information shall be classified as follows:

Classification	Examples	Minimum handling requirements
Public	Approved marketing content and public documentation	Integrity controls and authorized publication
Internal	Architecture, procedures, internal support notes, non-public configuration	Authenticated access and approved sharing
Confidential	Customer records, leases, financial data, contacts, maintenance records, audit logs	Least privilege, encryption in transit, tenant isolation, controlled export and retention
Restricted	Password hashes, OAuth refresh tokens, API keys, encryption keys, screening data, authentication secrets	Need-to-know access, approved secret storage, encryption at rest, no logging or source control

Restricted information shall never be placed in source code, tickets, chat messages, screenshots, test fixtures, or logs unless formally approved, redacted, and necessary for incident response.

Production customer information shall not be copied into development or test environments unless approved by the data owner and sanitized to remove identifying and sensitive content.

5. Identity and Access Management

5.1 General requirements

- Every person shall use a unique identity. Shared interactive accounts are prohibited unless explicitly approved and technically unavoidable.
- Access shall follow least privilege and role-based access principles.
- Access shall be removed promptly upon termination and adjusted promptly when responsibilities change.

- Privileged access shall be limited to authorized administrators and reviewed at least quarterly.
- Service accounts and integration identities shall be scoped to the minimum required permissions and shall not be used for interactive access.

5.2 Authentication

- Passwords shall be stored only as approved one-way password hashes.
- JWT signing secrets, default administrator passwords, database passwords, and encryption keys shall be strong, unique, and explicitly configured. Deployments shall fail closed when mandatory secrets are absent.
- Multi-factor authentication is mandatory for platform super-administrators and shall be required for other privileged roles where supported.
- Backup authentication codes shall be single-use, protected at rest, and displayed only during enrollment.
- Authentication failures shall be rate limited and monitored. Repeated failures shall trigger lockout or challenge invalidation according to approved thresholds.
- Enterprise single sign-on shall use approved OIDC authorization-code flows with issuer, audience, signature, expiration, nonce, and email-domain validation.

5.3 Privileged support and impersonation

- Platform support access shall be limited to authorized personnel with a documented business purpose.
- Impersonation shall be time-bound, attributable to the initiating administrator, and recorded in audit logs.
- Support personnel shall not access customer content unless necessary to resolve an authorized support request or security incident.

6. Tenant Isolation

- Every customer-owned record shall be associated with an organization identifier or scoped through an organization-owned parent record.
- Organization identifiers for new customers shall be randomly generated UUIDv4 values and shall not be treated as authorization secrets.
- The authenticated user's organization shall be derived server-side. Clients shall not be trusted to select an arbitrary organization context.
- Database reads, writes, exports, background jobs, integrations, caches, and search indexes shall enforce organization scope.
- Cross-tenant access tests and tenant-scoping static checks shall be part of the development and release process.
- PostgreSQL Row-Level Security may be used as defense in depth, but application-level organization scoping remains mandatory. RLS shall not be represented as universally enforced while rollout remains partial or disabled.
- A suspected cross-tenant disclosure shall be treated as a high-severity security incident.

7. Cryptography and Secret Management

- TLS shall protect all production browser, API, webhook, OAuth, and administrative traffic.
- Secrets shall be stored in approved environment secret stores or managed secret services and shall not be committed to source control.
- OAuth refresh tokens and third-party credentials stored by Portfolio Desk shall be encrypted using the configured application encryption key.
- Encryption keys shall be separated from encrypted data, restricted to the backend runtime and authorized operators, and backed up through an approved secure process.
- Key rotation shall be planned before execution. Because rotating `ENCRYPTION_KEY` invalidates stored third-party tokens, affected integrations shall be reconnected or migrated as part of the rotation plan.
- Logs and error responses shall not include passwords, bearer tokens, API keys, refresh tokens, full connection strings, or encryption keys.

8. Application and API Security

- Authorization shall be enforced on the server for every protected operation. Frontend route guards are usability controls and are not sufficient authorization.
- Input shall be validated using allowlists, structured schemas, length limits, and type constraints.
- File uploads shall enforce approved extensions, size limits, safe generated storage names, and download controls. Content-type validation and malware scanning shall be added where risk warrants.
- CORS shall use explicit approved origins. Credentialed wildcard origins are prohibited.
- Public endpoints shall disclose only information needed for their function.
- Rate limits shall protect authentication, signup, token exchange, public forms, and resource-intensive endpoints.
- Financial operations shall enforce balanced entries, organization ownership, idempotency, and an attributable audit trail.
- Webhooks shall use cryptographic signature verification, replay protections where available, bounded retries, and organization-scoped processing.

9. External Integrations and AI Services

9.1 General third-party requirements

Before enabling a third party that processes Confidential or Restricted information, the owner shall review:

- Security and privacy terms.
- Data use, retention, deletion, residency, and subcontractor practices.
- Authentication and least-privilege scopes.
- Breach notification commitments.
- Availability and exit procedures.

Third-party credentials shall be deployment secrets. Customer-specific OAuth grants shall be encrypted and organization-scoped.

9.2 QuickBooks and Plaid

- QuickBooks connections, company realm identifiers, account mappings, cursors, and sync records shall be isolated by Portfolio Desk organization.
- Plaid Items, access tokens, account mappings, transaction cursors, and sync records shall be isolated by organization.
- OAuth redirect URLs shall be explicitly registered and shall match deployed HTTPS URLs exactly.
- Sandbox environments shall be used before production activation.
- Imported and exported financial transactions shall preserve source attribution, idempotency, and auditability.

9.3 AI providers

- Only approved AI providers and models may process customer information.
- Provider selection, model identifiers, API keys, retention settings, and data-use terms shall be reviewed before production use.
- Prompts and documents shall contain only information necessary for the requested feature.
- AI output shall be treated as untrusted suggestions and shall require human review before creating legal, financial, compliance, or operational commitments.
- AI usage shall be metered and bounded to reduce denial-of-service and cost risk.
- Embeddings and generated output shall retain organization scope. A change of embedding model requires compatible vector dimensions and reindexing before semantic search is considered reliable.

10. Logging, Monitoring, and Audit

- Production systems shall emit structured logs at an approved level.
- Authentication events, privilege changes, organization changes, material record mutations, integration activity, and administrative actions shall be attributable to an identity and time.

- Security logs shall be protected from unauthorized modification and access.
- Logs shall exclude Restricted information and unnecessary customer content.
- Readiness monitoring shall include database connectivity and critical runtime components.
- Error tracking and alerting shall be configured for production based on risk and operational commitments.
- Time shall be synchronized across infrastructure used to create or analyze security records.
- Audit-log retention shall follow the applicable plan, contract, legal requirement, and approved retention schedule.

11. Data Retention and Disposal

- Data owners shall define retention periods based on business, contractual, legal, privacy, and security requirements.
- Customer-requested deletion shall be executed according to approved procedures, subject to legal holds and required financial or audit retention.
- Expired information shall be deleted or irreversibly anonymized from active systems and aged out of backups according to the approved backup lifecycle.
- Consumer screening information is subject to additional regulated retention and secure disposal obligations.
- Storage media and cloud resources shall be securely erased or cryptographically destroyed before reuse or release.

12. Secure Development and Vulnerability Management

12.1 Development lifecycle

- Security requirements shall be considered during design and threat modeling for material features.
- Code changes shall receive peer review before production deployment.

- Automated tests shall cover authentication, authorization, tenant isolation, financial integrity, input validation, and security-sensitive integrations according to change risk.
- Dependencies shall be pinned or constrained and reviewed for known vulnerabilities and unsupported versions.
- Secrets and sensitive files shall be excluded from repositories and build artifacts.
- Production changes shall be traceable to an approved source change and deployment record.

12.2 Vulnerability remediation targets

Unless management approves a documented exception, remediation shall be targeted as follows from confirmation of an applicable vulnerability:

Severity	Target
Critical	72 hours
High	14 calendar days
Medium	30 calendar days
Low	90 calendar days or accepted in the risk register

Actively exploited vulnerabilities may require immediate containment regardless of rating.

Security testing shall include dependency scanning, static analysis, tenant-isolation checks, focused penetration testing after material changes, and periodic independent review as risk and customer commitments require.

13. Change and Configuration Management

- Production configuration shall be managed through approved deployment mechanisms.
- Security-sensitive environment variables shall be documented, validated, and supplied through approved secret stores.
- Changes shall be tested in a non-production environment before release when practical.

- Database migrations shall be backed up, reviewed, reversible where practical, and validated before production rollout.
- Emergency changes shall be documented and retrospectively reviewed.
- Unsupported or ad hoc production changes shall be corrected into the controlled configuration source.

14. Backup, Recovery, and Availability

- Production databases and uploaded files shall be backed up through approved automated processes.
- Backups shall be encrypted, access controlled, non-public, and stored separately from the primary workload where practical.
- The approved schedule shall support a production recovery point objective of no more than 24 hours unless a contract requires a stricter target.
- Restore procedures shall be tested at least annually and after material backup architecture changes.
- Recovery tests shall verify database integrity, uploaded-file availability, tenant isolation, encryption-key availability, and critical application functions.
- Backup failures and readiness failures shall generate operational alerts and assigned follow-up.
- Recovery time objectives shall be defined and approved by management for each production deployment tier.

15. Incident Response

Portfolio Desk shall maintain an incident response process with the following phases:

1. **Preparation:** define contacts, severity levels, communication channels, evidence procedures, and access to logs and backups.
2. **Identification:** validate alerts and determine affected systems, organizations, data, identities, and time ranges.
3. **Containment:** revoke sessions and credentials, isolate affected components, suspend integrations, or restrict access as necessary.

4. **Eradication:** remove the cause, remediate vulnerabilities, rotate affected secrets, and validate system integrity.
5. **Recovery:** restore service carefully, monitor for recurrence, and confirm customer data and tenant boundaries.
6. **Lessons learned:** document root cause, timeline, impact, corrective actions, and control improvements.

Suspected incidents shall be reported immediately to the security owner. Evidence shall be preserved with access and handling records. Legal, privacy, contractual, insurer, law-enforcement, and customer notification obligations shall be assessed by authorized decision makers. No employee or contractor may make an external breach statement without authorization.

16. Business Continuity and Disaster Recovery

- Critical dependencies, recovery prerequisites, DNS, certificates, secrets, database access, object storage, and deployment artifacts shall be documented.
- Disaster recovery procedures shall identify responsible roles and alternate contacts.
- Recovery exercises shall be performed at least annually for production systems.
- Identified recovery gaps shall be tracked to closure or accepted through the exception process.

17. Physical and Endpoint Security

Personnel with administrative or source-code access shall:

- Use managed, supported devices with screen lock, disk encryption, malware protection where applicable, and timely security updates.
- Protect SSH keys, developer tokens, authenticator devices, and recovery codes.
- Avoid administrative access from untrusted or public devices.
- Report lost devices or suspected credential exposure immediately.

Cloud and hosting providers are responsible for physical datacenter controls under their service agreements. Portfolio Desk remains responsible for

provider selection, logical configuration, and access.

18. Security Awareness

Personnel with access to Portfolio Desk systems or customer information shall receive security and privacy awareness training at onboarding and at least annually. Training shall include phishing, credential handling, incident reporting, customer-data handling, secure development responsibilities where applicable, and use of AI or external services.

19. Exceptions and Risk Acceptance

Exceptions require a written record containing:

- The policy requirement being excepted.
- Business justification and scope.
- Risk and affected information or systems.
- Compensating controls.
- Accountable owner.
- Approval by the security owner and business owner.
- Expiration date and review schedule.

Exceptions shall be time-bound. An expired exception is not authorization to continue noncompliance.

20. Enforcement

Violations may result in access suspension, corrective action, contract remedies, or disciplinary action consistent with applicable agreements and law. Security controls may block deployment or access when mandatory requirements are absent.

21. Review and Maintenance

This policy shall be reviewed at least annually and when any of the following occurs:

- A material security incident.
- A significant change to architecture, hosting, identity, tenant isolation, financial processing, AI processing, or external integrations.
- A new legal, regulatory, contractual, or insurer requirement.
- A material audit or risk-assessment finding.

Document revisions and approvals shall be retained.

Appendix A: Current Application Control Profile

This appendix records the application posture at policy version 1.0. It is not a substitute for deployment verification.

Area	Current application control	Qualification or required follow-up
Tenant isolation	Organization-scoped models, server-derived user organization, tenant-scoping helpers and tests	PostgreSQL RLS is a limited opt-in pilot and is not universal
Organization IDs	New customer organizations use random UUIDv4 identifiers	UUIDs prevent enumeration but do not replace authorization
Authentication	Internal password authentication, JWT sessions, Google OAuth, optional OIDC SSO	Deployment secrets and allowed origins must be configured correctly
MFA	TOTP and single-use backup codes; mandatory enrollment for super-administrators	MFA failure throttling shall remain subject to security testing
Authorization	Server-side role and entitlement dependencies	Access reviews and endpoint regression tests remain

Area	Current application control	Qualification or required follow-up
		operational requirements
Secret storage	Required environment secrets; Fernet encryption for stored third-party tokens	<code>ENCRYPTION_KEY</code> must be set before production integrations are connected
Auditability	Activity logs, accounting audit checks, integration sync logs, structured application logs	Retention depends on plan, deployment, and log aggregation configuration
External integrations	Organization-scoped QuickBooks, Plaid, SSO, webhooks, Stripe, email and AI configuration	Each live provider requires sandbox validation and vendor review
AI	Configurable Gemini, OpenAI and OpenRouter generation and embeddings; usage limits; human-review workflow	Provider retention and training terms must be approved before production use
Backups	Documented PostgreSQL and uploaded-file backup and restore procedures; AWS production includes managed snapshots and S3 controls	Restore testing and recovery objectives require operational evidence
Monitoring	Health and readiness endpoints, structured logging, optional Sentry, background-job status	Alert routing and production log retention must be configured per deployment

Area	Current application control	Qualification or required follow-up
Secure development	Tests, migration controls, tenant-scoping lint, source-controlled deployment workflows	Periodic dependency, static and independent security testing is required

Appendix B: Related Documents

- docs/SECURITY_FINDINGS.md
- docs/RLS_EVALUATION.md
- backend/docs/TENANT_SCOPING.md
- docs/MFA_SETUP.md
- docs/OBSERVABILITY.md
- docs/backup-setup.md
- docs/INTEGRATIONS.md
- docs/ACCOUNTING_AUDIT.md
- docs/MIGRATIONS.md
- docs/AI_PROVIDERS.md